

Nmap

정의

- 네트워크 상의 호스트와 포트, 서비스를 자동으로 탐색하는 도구
- 패킷을 조작해 대상 서버의 응답 패턴을 분석하는 스캐너
- 열린 포트·취약 서비스·OS 지문까지 추출하는 정보수집 툴
- 실제 공격자·침해대응팀 모두에게 필수인 표준 도구

Nmap을 이해하는 관점

1) 포트 상태를 6가지로 세분화해서 표현하는 도구

: 다른 도구들은 열려있는지 닫혀있는지 여부만 알려주는데 반해, Nmap은 6가지로 세분화해서 표현

2) 플래그(TCP Flags)와 응답 패턴을 분석하는 패킷 엔진

3) 네 가지 모듈(Host/Scan/Detection/Timing)을 조합하는 프레임워크 포트 상태를 6가지로 세분화해서 표현하는 도구

Nmap 포트 상태 6가지

- open: 포트가 열려 있고 실제 서비스가 응답함
- closed: 포트는 열려 있지 않지만 호스트는 살아 있음 (RST 반환)
- filtered: 방화벽/필터 때문에 응답이 차단됨 (상태 판단 불가)
- unfiltered: 필터링은 없지만 포트 상태를 명확히 알 수 없음
- open|filtered: 열려 있거나 필터링된 상태 (UDP 등 응답 없는 경우)
- closed|filtered: 닫혔거나 필터링된 상태 (드물게 사용되는 표현)

**참고

- TCP 3way handshake

SYN(신호보냄) >> SYN/ACK >> ACK(확인)

- TCP 4way handshake

(Client)Fin > (Server)ACK > (Server) Fin > (Client)ACK

Nmap 스캔의 4단 구조

>> 단순한 명령어로 끝나는것이 아닌 4단계를 거침

- 1) Host Discovery: 살아있는 호스트인지 먼저 판별
- 2) Scan Type: 어떤 방식(TCP/UDP/플래그)으로 포트를 건드릴지 결정
- 3) Service/OS Detection: 서비스 버전과 운영체제 지문 분석 (무엇이 돌아가고있는지 알아봄)
- 4) Timing / Evasion: 속도, 우회 기법, 탐지 회피 전략 조절

1. Host Discovery

>> 반응패턴을 보고 살아있는지 확인해보는 단계

- ICMP Ping: 가장 기본적인 생존 확인 방식
- SYN Ping(-PS): 특정 포트로 SYN을 보내 SYN/ACK 응답 여부 확인
SYN PING = SYN > SYN/ACK
 > 핸드셰이크의 1단계만 사용하여 생존여부만 확인하는 방식
- ACK Ping(-PA): ACK를 보내 RST 응답 여부로 호스트 판단
ACK PING = ACK
- UDP Ping(-PU): UDP 전송 후 ICMP Port Unreachable 응답 확인
- -Pn: 호스트 탐지 단계 생략 후 바로 포트 스캔 진행

2. Scan Type(스캔 방식) 개요 [핵심]

- ICMP Ping: 가장 기본적인 생존 확인 방식
- SYN Ping(-PS): 특정 포트로 SYN을 보내 SYN/ACK 응답 여부 확인
- ACK Ping(-PA): ACK를 보내 RST 응답 여부로 호스트 판단
- UDP Ping(-PU): UDP 전송 후 ICMP Port Unreachable 응답 확인
- -Pn: 호스트 탐지 단계 생략 후 바로 포트 스캔 진행
- TCP Connect Scan(-sT): OS가 직접 3-Way Handshake를 수행
- SYN Scan(-sS): SYN → SYN/ACK → RST로 연결을 고의로 미완성(스텔스)
- UDP Scan(-sU): UDP 전송 후 ICMP 에러 응답을 기반으로 상태 추정 : 응답이 거의 없음
- 플래그 스캔(-sN/-sF/-sX): NULL/FIN/XMAS로 방화벽 정책과 OS 특성 테스트

3. 서비스 / OS 탐지

•서비스 탐지

-**HTTP** GET : request/response 구조라서 GET 또는 HEAD 요청을 보내면 서버는 반드시 HTTP 헤더와 버전 정보를 포함한 응답을 돌려줌

-**SSH** Key init : 연결직후 “ 자기 버전을 먼저 말하는 배너(SSH-2.0-OpenSSH_9.2)”를 보냄

-**FTP** banner : 연결직후 220 Service ready 배너

-SMTP HELO

-그 외 프로토콜 별 테스트 패킷

: 각 프로토콜별로 고유한 패킷을 보내서 패턴을 감지하는 방식

: 배너패턴을 데이터베이스화 시켜서 추론할수 있음

•OS 탐지

-TTL : 패킷을 만들때 고정된 TTL값을 만들게 됨

-Window Size

-DF Flag

-RST 패킷 생성 방식

-ISN 증가 패턴

-ICMP 응답 패턴

4. Timing / Evasion - 속도조절할수 있다는 개념(탐지 우회에 직결되는)

•Timing Template(-T0~T5)

-T0 = 느리고 조용함(걸릴확률 낮음)

-T5 = 빠르고 시끄러움 (걸릴확률 높음)

•Evasion 기법

-Fragmentation (-f) → 패킷을 쪼개서 방화벽 우회

-Decoy (-D) → 가짜 IP 섞기

-Spoofing (-S) → 출발지 위조

---scan-delay → 패킷 단위 딜레이로 IDS 회피

스텔스 스캔(-sS) vs Connect 스캔

- Connect(-sT): SYN → SYN/ACK → ACK → 정확하지만 시끄러운 스캔 (서버 로그에 잘 남음)
- SYN(-sS): SYN → SYN/ACK → RST, 연결을 만들지 않고 상태만 확인

TCP vs UDP 관점에서 보는 스캔(-sTU)

- TCP: 연결 기반 프로토콜 → 반응(ACK/RST)이 항상 존재
- UDP: 비연결성 프로토콜 → '응답 없음'이 정상인 경우가 많음
- UDP 포트가 닫힌 경우: ICMP Port Unreachable 응답으로 closed 판단
- 응답이 전혀 없으면 Nmap은 open|filtered로만 표현 (정확한 구분 불가)

→ 같은 Nmap 스캔이어도 TCP/UDP에 따라 결과 해석 방식이 달라짐

플래그 스캔(NULL/FIN/XMAS) (-sN,-sF,-sX)

- 방화벽은 일반적으로 SYN 기반 연결 시도를 우선적으로 차단
- NULL 스캔(-sN): 플래그가 전혀 없는 비정상 TCP 패킷
- FIN 스캔(-sF): FIN 플래그만 설정된 패킷으로 포트 응답 관찰
- XMAS 스캔(-sX): FIN+PSH+URG 등 여러 플래그를 켜 패킷
- OS마다 이런 비정상 플래그에 대한 반응이 달라서 우회·지문 분석에 활용

Version/OS 스캔(-sV)

- 서비스 배너 분석
- Nmap의 서비스 프로브(DB 기반)
- 서비스 악성 버전 탐지(취약점 선제 조사)
- 단순 포트 열림 여부가 아니라 정확한 버전 번호까지 얻어 불필요한 공격 시도를 줄이는 데 사용

Timing / Evasion 개념(-T0 -T5)

- -T0 ~ -T5 옵션으로 스캔 속도와 간격 조절 (느릴수록 조용, 빠를수록 시끄러움)
- 느린 스캔: IDS/IPS 탐지를 회피하는 대신 시간이 오래 걸림
- 빠른 스캔: 짧은 시간에 많은 포트를 조사하지만 탐지 위험 증가
- Fragmentation(-f), Decoy(-D) 등은 패킷 분할·위장으로 정책 우회를 시도

Nmap 이론 요약

- Nmap은 포트 상태를 6가지로 표현하는 패킷 기반 네트워크 분석 도구
- 스캔 작업은 Host Discovery, Scan Type, Detection, Timing 4단 구조로 이해
- TCP/UDP 차이, 플래그 조작, 서비스/OS 지문 분석이 핵심 이론
- 실습에서는 이 이론을 바탕으로 스텔스 스캔, UDP 스캔, 플래그 스캔, 타이밍 조절을 경험하게 됨

[실습]

1장. 스텔스 스캔 vs Connect 스캔

<< sudo nmap -sT -p22 172.16.29.11 >> TCP Connect

<< sudo nmap -sS -p22 172.16.29.11 >> 스텔스

2장. TCP 스캔 vs UDP 스캔

<< sudo nmap -sT -p22-35 172.16.29.11 >> +

<< sudo nmap -sU -p53,54 172.16.29.11 >> =

<< sudo nmap -sT -sU -p T:22-35,U:53,54 172.16.29.11>>

3장. NULL, FIN, XMAS 스캔

<< sudo nmap -sN -p22-35 172.16.29.11 >> "NULL"

<< sudo nmap -sF -p22-35 172.16.29.11 >> "FIN"

<< sudo nmap -sX -p22-35 172.16.29.11 >> "XMAS"

4장. Version 스캔과 OS 스캔

<< sudo nmap -sV -p22,80 172.16.29.11 >> 서비스별 버전

<< sudo nmap -O 172.16.29.11 >> OS

5장. Timing 옵션과 IDS 우회

<< sudo nmap -sS -T1 -Pn -p- 172.16.29.11 >> 조용 느릿

<< sudo nmap -sS -T4 -p- 172.16.29.11 >> 빠름 시끌

[명령어 정리]

1. 대상 지정 및 기본 스캔 (Target & Basic)

명령어	설명
nmap [IP]	기본 스캔 (가장 일반적)
nmap [IP1] [IP2] [IP3]	여러 호스트를 동시에 스캔
nmap [IP]/24	CIDR 표기법으로 대역 전체 스캔
nmap 192.168.0.1-50	특정 IP 범위 지정 스캔
nmap -iL hosts.txt	파일 목록에서 대상 IP 불러오기
nmap --exclude [IP]	스캔 범위에서 특정 IP 제외
nmap --excludefile [FILE]	파일 목록에 있는 IP들을 제외
nmap -6 [IP]	IPv6 주소 스캔

2. 호스트 발견 및 DNS (Host Discovery)

명령어	설명
nmap -sn [IP]	포트 스캔 없이 호스트 활성화 여부만 확인 (Ping Scan)
nmap -Pn [IP]	Ping을 보내지 않고 무조건 스캔 (방화벽 차단 시 유용)
nmap -n [IP]	DNS 역방향 조회(Rreverse DNS) 하지 않음 (속도 향상)
nmap -R [IP]	모든 호스트에 대해 DNS 역방향 조회 강제
nmap --dns-servers [IP]	시스템 기본 DNS 대신 특정 DNS 서버 사용
nmap --traceroute [IP]	스캔 결과에 경로 추적(traceroute) 정보 포함
nmap -PE [IP]	ICMP Echo 요청으로 핑 (기본 핑)
nmap -PP [IP]	ICMP Timestamp 요청으로 핑
nmap -PM [IP]	ICMP Netmask 요청으로 핑

nmap -PS[PORT] [IP]	TCP SYN 패킷을 보내 호스트 확인 (예: -PS80,443)
nmap -PA[PORT] [IP]	TCP ACK 패킷을 보내 호스트 확인
nmap -PU[PORT] [IP]	UDP 패킷을 보내 호스트 확인
nmap -PR [IP]	ARP 요청으로 로컬 호스트 확인 (가장 빠름)

3. 포트 스캔 기법 (Scan Techniques)

명령어	설명
nmap -sS [IP]	SYN 스캔 (스텔스 스캔, 가장 많이 사용, root 권한 필요)
nmap -sT [IP]	Connect 스캔 (로그가 남음, 권한 없을 때 사용)
nmap -sU [IP]	UDP 스캔 (UDP 포트 확인, 속도가 느림)
nmap -sSU [IP]	TCP(SYN)와 UDP를 동시에 스캔
nmap -sN [IP]	NULL 스캔 (플래그 없음, 우회용)
nmap -sF [IP]	FIN 스캔 (FIN 플래그만 설정, 우회용)
nmap -sX [IP]	XMAS 스캔 (FIN, PSH, URG 설정, 우회용)
nmap -sA [IP]	ACK 스캔 (포트 오픈 여부보다 방화벽 규칙 확인용)
nmap -sW [IP]	Window 스캔 (TCP 윈도우 크기 확인)
nmap -sM [IP]	Maimon 스캔
nmap -sO [IP]	IP 프로토콜 스캔 (TCP, UDP, ICMP 등 지원 여부 확인)
nmap -sL [IP]/24	패킷을 보내지 않고 대상 목록(DNS 이름)만 출력
nmap -sl [ZOMBIE] [IP]	Idle 스캔 (좀비 PC를 이용해 IP 숨기기)

4. 포트 지정 및 서비스/OS 탐지 (Port, Version & OS)

명령어	설명
<code>nmap -p- [IP]</code>	1~65535 전체 포트 스캔
<code>nmap -p[PORT] [IP]</code>	특정 포트만 스캔 (예: <code>-p80</code> , <code>-p22,80</code>)
<code>nmap -p[1-100] [IP]</code>	포트 범위 지정 스캔
<code>nmap --top-ports [N] [IP]</code>	가장 많이 쓰이는 상위 N개 포트 스캔
<code>nmap -sV [IP]</code>	열린 포트의 서비스 버전 확인
<code>nmap -sV --version-intensity [0-9]</code>	버전 탐지 강도 설정 (9가 가장 강력하고 느림)
<code>nmap -O [IP]</code>	운영체제(OS) 탐지
<code>nmap -O --osscan-guess</code>	OS 추측 강도 높임
<code>nmap -A [IP]</code>	종합 스캔 (OS + 버전 + 스크립트 + Traceroute)